

AURA Dealership OS — GCP Architecture (DEV & PROD)

Resource	DEV (aura-dev)	PROD (aura-prod)	Reason
Compute — MIG (Node API)	e2-standard-2, min 2 / max 4, multi-zone, Shielded VM	e2-standard-2, min 2 / max 6, multi-zone, autoscale CPU 60%, rolling deploys (surge 1 / unavail 0)	Autoscaled VMs, zero-downtime deploys, zone-failure tolerance, high uptime
Load Balancer	Global HTTPS LB, managed TLS	Same + HSTS	Single hardened entry, Google-edge DDoS absorption
WAF — Cloud Armor	Same rules, log-only (preview)	Enforced: geo-allowlist Guyana, OWASP rules, 60 req/min per IP (10/min on auth + agent endpoints), reCAPTCHA on login	GY-only geo-fence removes ~99% of attack surface; rate caps stop brute force & LLM cost abuse
API Gateway	OpenAPI spec, JWT validation	Same + per-consumer API keys/quotas	Schema-validated API surface; controlled machine-to-machine access
Frontends	Cloud Storage + Cloud CDN (AURA, Realm buckets)	Same + versioning + CMEK	Fast, cheap SPA delivery off the VMs; smaller attack surface
OLTP — Cloud SQL PostgreSQL	db-custom-1-3840, single-zone, private IP, 7-day backups	db-custom-2-8192, regional HA (auto-failover), PITR, 30-day + cross-region backups, CMEK, IAM DB auth	System of record; HA uptime; recover from bad deploys/deletion; unreachable from internet
NoSQL — Firestore (agents)	Own DB, relaxed TTL	TTL (90-day sessions), daily backups, server-only access	Agent sessions, feedback, conversation history, doc-extracted data; serverless, zero ops
OLAP — BigQuery	Own dataset, on-demand pricing	Datasets fed by Datastream (Cloud SQL CDC) + nightly Firestore export; CMEK; authorized views for reporting; inside VPC-SC perimeter	Analytics/reporting (sales trends, agent usage, duty filings) off the OLTP database - heavy queries never slow the app
AI — Claude Sonnet 4.6	Vertex AI Model Garden (Anthropic), in-region endpoint	Same + per-project quotas, token-spend budget alerts	Only model the product uses; Vertex (not Bedrock) keeps it single-cloud: IAM auth, no keys, VPC-SC coverage
Cache — Memorystore Redis	Basic 1 GB, AUTH + TLS	Standard (HA) 1 GB, AUTH + TLS	Sessions, idempotency, queues; HA replica protects uptime in PROD
Documents — Cloud Storage	Uniform access, signed URLs	Same + versioning + CMEK	Fail-closed access to customer uploads
Egress — Cloud NAT	1 gateway	1 gateway, logging on	No public IPs on VMs; outbound-only internet (Twilio, Gmail)
Secrets — Secret Manager	Dev-only keys, SA-scoped	CMEK, 90-day rotation, access audit logs	No credentials in code, images, or metadata
SSO — Identity Platform	Google provider, domain-restricted	Same; app RBAC stays in Postgres	Google SSO for staff; hd claim verified server-side
Admin wall — IAP	Optional on Realm	Required on Realm + used for all SSH (no open ports)	Second Google-enforced auth wall on super-admin; keyless VM access

Perimeter — VPC-SC	—	Perimeter around SQL, Firestore, GCS, Secret Manager	Blocks data exfiltration even with stolen credentials
Supply chain	Artifact Registry + vuln scanning	Same + Binary Authorization (CI-signed images only)	Compromised laptop cannot deploy to PROD
Observability	Logging, Monitoring, Trace, Error Reporting, uptime check	Same + alerts (5xx>2%, p95>1.5s, SQL disk, login-failure & WAF-deny spikes, budget) + 400-day locked log sink	Detect outages/attacks in minutes; tamper-proof audit trail
Posture	Web Security Scanner weekly	Security Command Center Standard	Continuous misconfig & exposure detection
Access & deploys	Devs via IAP + OS Login; CI deploys on merge	CI-only with manual approval; no standing human access	Blast-radius isolation between environments
IaC / CI-CD	Terraform (GCS state) + GitHub Actions via Workload Identity Federation	Same, prod tfvars + approval gate	Reviewed, reproducible infra; keyless deploys from GitHub
Est. cost / month	~US\$300–450	~US\$600–900 (excl. LLM tokens)	Smallest sensible tiers; scales 100x by resizing, not re-architecting